

05

Autenticação, Autorização e Criptografia

Senhas, MFA, hashing, criptografia, certificados e assinaturas digitais

Curso Técnico em Desenvolvimento de Sistemas

Capítulo planejado para aproximadamente 5 horas-aula

Material de apoio didático • teoria, laboratório e revisão

Base curricular

Este capítulo foi estruturado a partir das bases tecnológicas do componente Segurança de Sistemas de Informação do curso Técnico em Desenvolvimento de Sistemas do Centro Paula Souza. A coleção expande a ementa com exemplos e atividades de laboratório.

Objetivos de aprendizagem

- Diferenciar identificação, autenticação e autorização.
- Explicar fatores de autenticação e o papel do MFA.
- Distinguir criptografia, hashing e assinatura digital.
- Aplicar boas práticas de armazenamento de senhas e proteção de chaves.

Alinhamento curricular

Abrange métodos de autenticação e autorização, criptografia, hashing, certificados e assinaturas digitais previstos na ementa.

1. Identidade, autenticação e autorização

Identificação é declarar quem se é; autenticação é comprovar a identidade; autorização decide o que a identidade pode fazer. Misturar esses conceitos gera falhas: um usuário corretamente autenticado pode acessar dados de outro se a autorização estiver incorreta.

O princípio do menor privilégio limita permissões ao necessário. Modelos comuns incluem RBAC, baseado em papéis, e ABAC, baseado em atributos e contexto.

2. Fatores de autenticação e MFA

Fatores costumam ser agrupados em conhecimento, posse e característica inerente. Senha é conhecimento; token ou aparelho pode representar posse; biometria é inerência. MFA combina fatores diferentes, reduzindo o impacto de uma senha vazada.

MFA não elimina todos os riscos: phishing em tempo real, recuperação de conta fraca e sequestro de sessão ainda importam. Processos de recuperação precisam ser tão seguros quanto o login principal.

3. Senhas e hashing

Senhas não devem ser armazenadas de forma reversível. O servidor guarda um hash derivado por algoritmo apropriado para senhas, com salt exclusivo por registro e custo configurável. Funções rápidas genéricas não são a escolha ideal para senha porque facilitam tentativas em massa.

Na implementação, prefira bibliotecas modernas da plataforma, que normalmente oferecem Argon2, scrypt, bcrypt ou PBKDF2. Nunca invente um algoritmo próprio.

```
# Pseudocódigo conceitual
salt = gerar_aleatorio()
hash = derivar_senha(senha, salt, custo)
salvar(usuario, salt, hash)
```

No login: derivar novamente e comparar de forma segura.

4. Criptografia simétrica e assimétrica

Criptografia simétrica usa a mesma chave para cifrar e decifrar e é eficiente para grande volume de dados. Criptografia assimétrica usa par de chaves pública e privada e facilita troca de chaves, identidade e assinaturas. Sistemas reais combinam as duas abordagens.

Proteção de chaves é parte central. Uma chave privada exposta compromete o sistema mesmo que o algoritmo seja forte. Segredos não devem ficar embutidos no código-fonte ou enviados ao repositório.

5. Certificados e assinatura digital

Certificados digitais associam uma chave pública a uma identidade por meio de uma cadeia de confiança. Em HTTPS, certificados ajudam o cliente a autenticar o servidor e estabelecer canal protegido.

Assinatura digital permite verificar origem e integridade com criptografia assimétrica. Ela não é o mesmo que “imagem de assinatura” em documento; depende de operações criptográficas e proteção da chave privada.

Laboratório e aplicação prática

Prática 5 - Modelagem de login seguro

Objetivo: Projetar o fluxo de autenticação de uma aplicação sem armazenar senhas em texto puro.

1. Desenhe as etapas de cadastro: validação mínima, geração de salt, derivação do hash e armazenamento.
2. Desenhe as etapas de login: busca da conta, verificação segura e tratamento de erros sem revelar detalhes excessivos.
3. Inclua MFA opcional ou obrigatório para uma operação sensível.
4. Defina política de recuperação de conta e proteção contra tentativas automatizadas.
5. Liste onde segredos e chaves seriam armazenados no ambiente de produção.

Entrega sugerida: Um diagrama de sequência do cadastro e login, acompanhado de uma lista de decisões de segurança.

Questões de fixação

1. Qual é a diferença entre autenticação e autorização?
2. Por que senha deve ser armazenada com função apropriada de derivação de senha e salt?
3. O que caracteriza MFA?
4. Qual é a principal diferença entre criptografia simétrica e assimétrica?
5. Por que segurança de recuperação de conta é crítica?

Como estudar

Responda primeiro sem consultar o texto. Depois compare sua resposta com o resumo do capítulo e complemente o que faltou.

Resumo do capítulo

- Autenticação comprova identidade; autorização controla permissões.
- MFA combina fatores diferentes e reduz impacto de credenciais vazadas.
- Senhas devem ser verificadas por hashes resistentes a tentativa em massa.
- Criptografia protege confidencialidade; hashing e assinaturas têm objetivos diferentes.
- Chaves e segredos precisam de armazenamento e ciclo de vida seguros.

Glossário essencial

Termo	Definição
MFA	Autenticação multifator.
Salt	Valor aleatório único combinado à senha antes da derivação do hash.
Hashing	Transformação unidirecional usada para integridade e verificação.
Chave pública	Parte de um par assimétrico que pode ser distribuída.
Chave privada	Parte secreta de um par assimétrico.
Certificado digital	Documento eletrônico que associa identidade e chave pública.

Referências e materiais de consulta

- Centro Paula Souza. Plano de Curso do Técnico em Desenvolvimento de Sistemas, componente Segurança de Sistemas de Informação.
- CERT.br. Cartilha de Segurança para Internet. Conteúdo de conscientização e boas práticas de segurança.
- ISO/IEC 27001. Sistemas de gestão de segurança da informação - requisitos e princípios de gestão.
- OWASP Foundation. OWASP Top 10:2025 e materiais de segurança de aplicações web.